

MEDICARE CONNECT (PTY) LTD
SOC 2 CLOUD CONTROL IMPLEMENTATION REPORT
AWS Free Tier Technical Evidence Mapping

Classification	: Confidential
Version	: 1.0
Date	: March 2026
Author	: Patrick Mohlala, GRC Analyst
Distribution	: CEO, IT Manager, Information Officer

1. EXECUTIVE SUMMARY

This report presents the results of mapping AWS Free Tier security configurations to SOC 2 Trust Services Criteria (Security), with cross-mapping to ISO/IEC 27001:2022 and POPIA Section 19.

The sandbox demonstrates that core technical controls can be implemented and evidenced:

- MFA
- Password policy
- CloudTrail logging
- S3 encryption
- Public access blocking
- Restrictive network rules
- Monitoring alarms
- Backup configuration

Result snapshot:

- Controls mapped: 18
- Implemented: 11
- Partial: 7
- Missing: 0
- Evidence artifacts indexed: 12

2. BUSINESS PROBLEM

Projects 1 to 4 produced strong governance documentation.

A remaining gap was technical operating evidence.

Without screenshots and control mapping, MediCare Connect cannot convincingly answer customer security questionnaires or internal audit requests about cloud safeguards.

3. OBJECTIVES

- Configure a low-cost AWS sandbox
- Implement foundational security settings
- Map settings to SOC 2, ISO 27001, and POPIA
- Collect reusable evidence artifacts
- Identify residual gaps and a 30/60/90 plan

4. SCOPE

In scope:

- AWS Free Tier account security settings listed in the Scope Document

Out of scope:

- Real PHI/PII
- Formal external SOC 2 Type II examination
- Enterprise multi-account architecture

5. METHODOLOGY

Step 1: Define scope and success criteria

Step 2: Configure AWS Free Tier controls

Step 3: Capture screenshots and complete Evidence Artifact Log

Step 4: Complete Control Matrix in Google Sheets

Step 5: Rate each control as Implemented / Partial / Missing
Step 6: Document gaps and roadmap
Step 7: Produce this implementation report

6. CONTROL THEMES COVERED

- Identity and access management
- Privileged access protection (MFA)
- Audit logging and monitoring
- Encryption and data exposure prevention
- Network restriction
- Backup readiness
- Accountability and oversight

7. KEY FINDINGS

7.1 Strengths

- Root MFA enabled
- IAM password policy configured
- CloudTrail enabled with log validation
- S3 default encryption enabled
- S3 Block Public Access enabled
- Security groups documented as restrictive
- Evidence IDs assigned and traceable

7.2 Partial / Improvement Areas

- Continuous detection content is basic (CloudWatch only)
- Formal quarterly access certification process still manual
- Backup restore test evidence not yet completed
- No CSPM tool for continuous misconfiguration monitoring
- Change management ticket linkage is lightweight

8. COMPLIANCE INTERPRETATION

SOC 2:

Provides evidence toward Security criteria around logical access, monitoring, and risk mitigation.

ISO 27001:2022:

Supports Annex A themes including access control, logging, cryptography, network security, and backup.

POPIA:

Supports Section 19 expectations for appropriate technical and organisational measures to protect personal information.

9. BUSINESS IMPACT

With this evidence pack, MediCare Connect can:

- Respond faster to security questionnaires
- Show auditors technical proof, not only policies
- Reduce onboarding delays with enterprise customers
- Strengthen POPIA accountability narrative for cloud systems

10. 30 / 60 / 90 DAY ROADMAP

30 Days

- Enforce MFA for all IAM users
- Finalise IAM access review checklist
- Enable additional S3 access logging where relevant

60 Days

- Add AWS Config rules for encryption and public access
- Perform and document one backup restore test
- Improve log retention and alerting design

90 Days

- Evaluate CSPM tooling
- Publish cloud shared responsibility matrix to vendors/internal teams
- Conduct external SOC 2 readiness discussion

11. CONCLUSION

Project 5 closes the gap between documented GRC processes and technical proof.

It demonstrates practical ability to implement, evidence, and report cloud controls in language auditors and recruiters understand.

Document Control

Compiled by : Patrick Mohlala, GRC Analyst

Status : Final

Next Review : September 2026